

Confidentiality and Research Hygiene

v0.1

Purpose and limitation

本文件提供 AMAT 與未來企業客戶專案的工作守則，不是正式法律意見。公司正式 NDA、客戶 NDA、資訊安全政策、資料處理協議與客戶特定要求仍須另行確認；若有衝突，以正式要求為準並立即向 Project Lead 升級。

Core rule

只取得、使用、分享與保存完成工作所需的最少資訊。任何工具、裝置、雲端或外部對象在使用前，先確認它是否被授權接收該分類的資料。

Information classification concept

Classification	Examples	Default handling
Public	已公開法規、政府資料、公司正式公開揭露	可研究與引用；仍需記 source / date / scope
Internal	Optimum 方法、一般工作模板、非客戶特定 training	只供授權 Optimum 人員；不得任意公開
Client Confidential	client identity linked to consumption、sites、strategy、contracts、offers、stakeholders、meeting notes	need-to-know；使用核准 storage / transfer；不得貼入未授權工具
Highly Restricted	credentials、personal data、privileged legal material、unannounced transactions、detailed bids / pricing、security-sensitive data	只依明確授權、最小範圍與額外控制處理；有疑問即停止

Classification 尚未確認時，先採較高保護等級。

Need to know

- Access 依 role 與 task，不因同公司或參與專案就自動取得全部資料。
- 每次分享先確認 recipient、purpose、minimum fields、retention 與 onward sharing。

- 群組、shared link、mailing list 與 external guest 都可能擴大 audience；發送前逐一檢查。

File handling

- 使用專案核准位置與清楚命名；避免把 real client files 複製到個人下載、桌面或臨時分享位置。
- 不用真實 client data 作 training demo、工具測試、截圖或 sample。
- 傳送前移除 hidden sheets、comments、tracked changes、metadata、cached data 與錯誤附件。
- 權限採最小範圍；有到期日的 link 優先；結案依 retention rule archive / delete。

Personal devices and removable media

未獲正式允許，不在個人裝置、私人 email、私人雲端或 removable media 保存 client files。若公司政策允許 BYOD，仍須符合 encryption、screen lock、patch、remote wipe、approved apps 與 local download rules。

Cloud storage and external SaaS

上傳前確認服務、tenant、account、data residency、retention、training use、subprocessors、sharing default 與 client restriction。工具方便不等於已授權。不能確認時，改用 abstracted / synthetic data 或停止。

AI tool usage

- 不把 client identity、sites、volume、price、contract language、supplier proposal、personal data 或 privileged material 輸入未獲批准的 AI 工具。
- 即使是核准工具，也遵循 minimum necessary；能用 schema、匿名數字或 synthetic sample 解決，就不使用原始檔。
- 檢查 prompt、upload、conversation history、generated output 與 export 是否會保留或擴散 client data。
- AI output 不視為 evidence；重要 facts、calculations 與 legal / commercial statements 必須由人員驗證。

Copy paste screenshots messaging and email

- Copy / paste 可能帶入 hidden identifiers、comments 或不相關欄位；先移除。
- Screenshot 會暴露 window title、tabs、notifications、email addresses 與其他客戶資料；只截必要區域並檢查背景。
- 不用 consumer messaging 傳送 client files，除非正式批准。

- Email 前執行 recipient、attachment、classification、subject、link permission 與 reply-all check。
敏感附件優先使用核准 secure transfer。

Researching a confidential problem without leaking identity

把問題抽象成公開機制或一般條件，不提供 client-specific combination。例：

- 不可接受：公開詢問「AMAT Taiwan 每年需要 X GWh，哪家供應商可在 Y site 供應？」
- 可接受：研究「台灣企業綠電轉供流程通常涉及哪些角色與資料欄位？」
- 可接受：用合成 volume / fictional company 測試 calculation method。

如果多個抽象欄位組合後仍可重新識別 client，繼續減少細節或改用內部專家。

Handling real client files

1. 確認 classification、owner、permitted purpose 與 storage location。
2. 建立 working copy only when needed；保留原始來源與 checksum / version context。
3. 分離 raw client data、cleaned data、assumptions 與 outputs。
4. 任何轉換保留 data dictionary、mapping 與 quality log。
5. 分享 output 前執行 confidentiality review，特別檢查 hidden / embedded content。

Anonymisation

使用 stable ID 取代公司、site、person 與 supplier 名稱；generalize dates / volumes only to the extent analysis still works；移除 metadata and free text identifiers。Pseudonymisation 不等於匿名化，mapping key 仍屬敏感資料並分開保存。

Accidental disclosure response

採取 **Stop / Report / Contain / Document**：

6. **Stop**：停止發送、分享、同步或進一步處理；不要自行刪除 evidence。
7. **Report**：立即通知 Project Lead 與正式 security / privacy contact；說明 what、when、where、who may have access。
8. **Contain**：依指示撤回 email、關閉 link、移除權限、隔離裝置或要求 recipient 不開啟 / 刪除。
9. **Document**：記錄 timeline、data type、recipients、containment、remaining exposure 與 follow-up；不要淡化。

Pre-send checklist

- Recipient 與 need-to-know 正確。

- Artifact 中的 client / supplier confidential fields 是最少必要。
- 沒有 hidden sheets、notes、comments、metadata 或錯誤版本。
- 使用核准 channel、storage 與 access settings。
- AMAT-specific facts 的 status / source 可追溯。
- 若為 external research / AI / SaaS，資料已充分 abstract / anonymise 且工具已獲批准。

Escalation rule

不確定是否可處理或分享時，先停止並詢問 Project Lead / authorized security contact。時間壓力不是降低 confidentiality control 的理由。